

Lab Report

Lab Report

Time Spent: 27:21

Score: 3/3 (100%)

Pass

Passing Score: 3/3 (100%)

TASK SUMMARY

Lab Questions

Q1 Which response is received by the `'=0'` attack request?

Your answer: SQL Syntax Error

Correct answer: SQL Syntax Error

Q2 Which response is received from the `' or 0=0 #` attack request?

Your answer: Bad Request

Correct answer: Bad Request

Q3 Enter the request number for one of the successful attacks.

Your answer: 21, 22, 35, 39, or 48

Correct answer: 21, 22, 35, 39, or 48

EXPLANATION

Complete this lab as follows:

1. Open Burp Suite and turn off Intercept.
 - a. From the Favorites bar, select **burpsuite**.
 - b. Select **Next**.
 - c. Select **Start Burp**.
 - d. Select the **Proxy** tab.
 - e. Make sure the Intercept sub-tab is selected.
 - f. Select **Intercept is on** button to toggle the setting to *Intercept is off*.
 - g. Select the **HTTP history** sub-tab.
 - h. Drag the Burp Suite window to the lower part of the screen.
2. Lookup your account balance on mysecureonlinebank.com.
 - a. From the Favorites bar, select **Google Chrome**.
 - b. In Chrome's address bar, type **mysecureonlinebank.com** and then press **Enter**.
 - c. For the Account Number, type **90342** and then select **Lookup**.
3. Use Burp Suite to launch a simple payload attack against the mysecureonlinebank.com site.
 - a. From Burp Suite's HTTP history tab, right-click the **request** that shows **GET** in the Method column and the **account number** in the URL column, and then select **Send to Intruder**.
 - b. Maximize the Burp Suite window for better viewing.
 - c. Select the **Intruder** tab.

You will see mysecureonlinebank.com entered as host (target) to attack.
 - d. Select the **Positions** sub-tab.
 - e. Highlight the **90342** account number and then select **Add**.

Notice the new symbols added before and after the account number.
 - f. Select the **Payloads** sub-tab.

Under *Payloads Options [Simple list]*, a simple list of strings that can be used as payloads is loaded.
 - g. Examine the options listed for **Payload Options [Simple list]**.

These are the SQL injection attacks that will be attempted.
 - h. Select **Start Attack**.
4. Analyze the results of the payload attack.
 - a. As the attack progresses, observe the Length column. Notice the varying lengths of the captured responses.
 - b. Select response number **0**.

The Response, and its sub-tab named HTML, are selected by default and the response to the attack is shown in the lower pane.

Notice that:

- The payload was not modified and contains the original account number of 90342.
- The length was relatively small, only 779 bytes.
- The response to this attack was: **Good Day Blake Jackson: The balance for account ID 90342 is \$582.29**

You may need to expand the window to view the entire response.

c. Select response number **1**.

Notice that:

- The payload was changed to an apostrophe.
- The length was 848 bytes.
- The response to this attack was: **You have an error in your SQL syntax; check the...**
This means that the attack was unsuccessful.

d. Select response number **2**.

Notice that:

- The payload was changed to a quote mark.
- The length was 713 bytes.
- The response to this attack was blank. Only the **<div>** tags are shown.
This means that the attack was unsuccessful.

e. Select response number **3**.

Notice that:

- The payload was changed to a hash sign.
- The length was 866 bytes.
- The response to this attack was: **Your browser sent a request that this server could not understand.**
This means that the attack was unsuccessful.

f. Locate and select a response that is larger than **6600** bytes. Observe the response in the lower pane.

These larger packets are the successful attacks, as they are returning the account information for many users.

5. Answer the questions.

- In the top right, select **Answer Questions**.
- Answer the questions.
- Select **Score Lab**.